COLORADO
Information Security
Governor's Office of Information Technology

TS-CISO-006: Encryption Standard

Document ID	TS-CISO-006
Title	Encryption Standard
Executive Sponsor	Jill Fraser, Chief Information Security Officer
Issuing Authority	Governor's Office of Information Technology (OIT)
Applies to	All state government agencies, employees, contractors, vendors, and external users who access state government information systems and applications, regardless of location or device, including all applications, hosting environments, and physical and connected technologies.
Instrument Type	Standard
Version	3.0
Effective Date	01/31/2026
Last Updated	05/13/2026

Purpose

This standard defines security requirements for encryption use across all state information systems and applications, including on-premises and cloud environments. It supports compliance with the Colorado Information Security Policies (CISPs).

Scope

This standard applies to all state government agencies, employees, contractors, vendors, and external users who access state government information systems and applications, regardless of location or device. This includes all applications and hosting environments, and access to physical and connected technologies.

Requirements

Data Encryption General Requirement

Requirement	Detail
Encryption Scope	Ensure all data is encrypted when at-rest or being transmitted, whenever possible.
Algorithm and Protocol Use	FIPS 140-2 or higher approved encryption algorithms and protocols.
Password Protection	All stored passwords must be encrypted or hashed.

Data in Transit Protection

All transmitted data must be protected by using one of the following mandatory protocols:

Approved Protocol	Minimum Version/Type
Transport Layer Security (TLS)	1.2 or higher
Secure Shell (SSH)	SSH-2
Internet Protocol Security (IPsec)	Used for Virtual Private Networks (VPN)

Stored Data Protection

All stored sensitive data must be protected using one of the following minimum approved standards. This applies to media, files, and databases (including field-level encryption when implemented):

Approved Standard/Algorithm	Minimum Key Length/Curves
Advanced Encryption Standard (AES)	128 or higher
Rivest-Shamir-Adleman (RSA)	2048 bit or higher
Elliptic Curve Cryptography (ECC)	Approved curves

Encryption Key Management and Storage

Requirement Category	Detail
Separation	Encryption keys must be stored separately from the encrypted data they protect.
Key Storage System	Keys must be stored and managed within a Hardware Security Module (HSM) or a dedicated, FIPS 140-2 Level 2 or higher compliant Key Management System (KMS). Keys must be stored under strict access controls.
Key Generation	Keys must be generated using cryptographically secure pseudorandom number generators (CSPRNGs).
Key Access	Access to keys must be governed by the Principle of Least Privilege and strictly logged.
Key Transfer	Keys must be transferred securely only to authorized encryption modules or entities.
Key Rotation	Key rotation must be performed at least annually.
Key Destruction	Keys must be securely zeroized or destroyed when they expire, are compromised, or are no longer needed.

Exceptions

All exceptions must be documented, justified, and approved by the State of Colorado's Chief Information Security Officer (CISO) or other designated authority. Compensating controls must be documented, implemented, and maintained.

Compliance

The Information Security Office will monitor and advise on compliance with this standard.